



Vertrag zur Auftragsverarbeitung gemäß Art. 28 DSGVO

zum Dienstleistungsvertrag „TattooFin“

zwischen dem **Kunden** (Studio) laut Dienstleistungsvertrag als **Verantwortlichem** („Auftraggeber“)

und **DSX Media Solutions UG (haftungsbeschränkt)**, [Straße Nr., PLZ Ort], als **Auftragsverarbeiter** („Auftragnehmer“).

§ 1 Gegenstand und Dauer

1. Der Auftragnehmer verarbeitet personenbezogene Daten im Auftrag des Auftraggebers im Rahmen der Bereitstellung der TattooFin-Plattform: Erstellung und Bereitstellung von Zahlungslinks und der Zahlseite des Studios, Anzeige von Zahlungsinformationen im Studio-Portal, Versand von Benachrichtigungen sowie Support. Einzelheiten zu Art und Zweck der Verarbeitung, Datenarten und betroffenen Personen enthält Anlage 1.
2. Die Zahlungsabwicklung selbst erfolgt durch Stripe und, je nach Zahlungsart, durch weitere Zahlungsanbieter, mit denen der Auftraggeber bzw. der Endkunde eigene Verträge geschlossen hat. Diese verarbeiten personenbezogene Daten im Rahmen der Zahlungsabwicklung (z. B. Karten- und Bankdaten, Identitäts- und Bonitätsprüfung) in eigener Verantwortung bzw. als Vertragspartner des Auftraggebers nach ihren eigenen Bedingungen. Sie sind insoweit keine Unterauftragsverarbeiter des Auftragnehmers, und diese Verarbeitung ist nicht Gegenstand dieses Vertrags.
3. Soweit der Auftragnehmer über die Stripe-Connect-Schnittstelle Daten aus dem Stripe-Konto des Auftraggebers abrufen oder dorthin übermittelt, um Zahlungslinks zu erstellen und Zahlungen im Studio-Portal anzuzeigen, gehört dies zur Verarbeitung nach diesem Vertrag.
4. Die Dauer dieses Vertrags entspricht der Laufzeit des Dienstleistungsvertrags. Verpflichtungen zur Löschung und Vertraulichkeit gelten darüber hinaus fort.

§ 2 Weisungsbefugnis

1. Der Auftragnehmer verarbeitet die Daten nur auf dokumentierte Weisung des Auftraggebers, es sei denn, er ist gesetzlich zur Verarbeitung verpflichtet; in diesem Fall teilt er dem Auftraggeber die rechtlichen Anforderungen vor der Verarbeitung mit, sofern das Gesetz dies nicht verbietet.
2. Die Weisungen ergeben sich aus dem Dienstleistungsvertrag, den Einstellungen und Eingaben des Auftraggebers im Studio-Portal und diesem Vertrag. Weitere Weisungen erteilt der Auftraggeber in Textform.
3. Ist der Auftragnehmer der Ansicht, dass eine Weisung gegen Datenschutzvorschriften verstößt, weist er den Auftraggeber unverzüglich darauf hin.

§ 3 Pflichten des Auftragnehmers

1. Der Auftragnehmer verpflichtet alle Personen, die Zugang zu den Daten haben, zur Vertraulichkeit.
2. Er trifft die technischen und organisatorischen Maßnahmen nach Art. 32 DSGVO gemäß Anlage 2 und passt sie dem Stand der Technik an, ohne das Schutzniveau zu unterschreiten.
3. Er unterstützt den Auftraggeber mit geeigneten Maßnahmen bei der Erfüllung der Rechte betroffener Personen (Art. 12 bis 23 DSGVO), insbesondere bei Auskunft und Löschung. Anfragen von Betroffenen, die direkt beim Auftragnehmer eingehen, leitet er unverzüglich weiter.
4. Er unterstützt den Auftraggeber bei den Pflichten aus Art. 32 bis 36 DSGVO (Sicherheit, Meldung von Datenschutzverletzungen, Datenschutz-Folgenabschätzung, vorherige Konsultation).
5. Verletzungen des Schutzes personenbezogener Daten meldet er dem Auftraggeber unverzüglich, möglichst innerhalb von 24 Stunden nach Bekanntwerden, mit den Informationen nach Art. 33 Abs. 3 DSGVO, soweit

verfügbar.

6. Er führt ein Verzeichnis der Verarbeitungstätigkeiten nach Art. 30 Abs. 2 DSGVO.
7. Er verwendet die Daten nicht für eigene Zwecke. Zur Abrechnung seiner Vergütung nach dem Dienstleistungsvertrag nutzt er Zahlungsbeträge, Zeitpunkte und Referenzen der abgewickelten Zahlungen; Endkundendaten werden dafür nur verarbeitet, soweit sie zur Nachvollziehbarkeit der Abrechnung erforderlich sind. Anonymisierte, nicht personenbezogene Nutzungsstatistiken darf er zur Verbesserung des Dienstes verwenden.

§ 4 Unterauftragsverarbeiter

1. Der Auftraggeber genehmigt die in Anlage 3 genannten Unterauftragsverarbeiter.
2. Der Auftragnehmer informiert den Auftraggeber in Textform über beabsichtigte Änderungen (Hinzuziehung oder Ersetzung) mindestens 14 Tage vorher. Der Auftraggeber kann innerhalb dieser Frist aus wichtigem datenschutzrechtlichem Grund widersprechen. Ist eine Fortführung ohne den Unterauftragsverarbeiter nicht zumutbar, steht beiden Parteien ein Sonderkündigungsrecht zu.
3. Der Auftragnehmer verpflichtet Unterauftragsverarbeiter vertraglich auf die Pflichten dieses Vertrags (Art. 28 Abs. 4 DSGVO).

§ 5 Übermittlung in Drittländer

Eine Verarbeitung außerhalb der EU bzw. des EWR erfolgt nur, wenn die Voraussetzungen der Art. 44 ff. DSGVO erfüllt sind, insbesondere auf Grundlage eines Angemessenheitsbeschlusses (z. B. EU-US Data Privacy Framework für zertifizierte Empfänger) oder der EU-Standardvertragsklauseln. Der Auftragnehmer nutzt, soweit angeboten, Datenverarbeitung in der EU.

§ 6 Kontrollrechte

Der Auftraggeber kann sich von der Einhaltung dieses Vertrags überzeugen, vorrangig durch Einholung von Auskünften und Nachweisen (z. B. Zertifikate und Berichte der Unterauftragsverarbeiter). Vor-Ort-Kontrollen sind nach rechtzeitiger Anmeldung (mindestens 14 Tage) während der Geschäftszeiten und ohne Störung des Betriebs möglich.

§ 7 Speicherdauer, Löschung und Rückgabe

1. Daten zu Zahlungslinks und Zahlungen werden für die Dauer des Dienstleistungsvertrags gespeichert, damit der Auftraggeber die Zahlungsübersicht im Studio-Portal nutzen kann. Auf Weisung des Auftraggebers löscht der Auftragnehmer einzelne Datensätze vorher, soweit keine Aufbewahrungspflicht entgegensteht.
2. Abrechnungsunterlagen des Auftragnehmers (Rechnungen und deren Grundlagen) bewahrt dieser im Rahmen der gesetzlichen Aufbewahrungsfristen auf. Insoweit handelt er als Verantwortlicher für die Erfüllung eigener gesetzlicher Pflichten.
3. An den Auftraggeber übermittelte Benachrichtigungen (z. B. E-Mails) sowie Daten im Stripe-Konto des Auftraggebers liegen in dessen Verantwortung.
4. Nach Vertragsende löscht der Auftragnehmer alle personenbezogenen Daten des Auftraggebers innerhalb von 30 Tagen bzw. gibt sie auf Wunsch vorher heraus, sofern keine gesetzliche Pflicht zur Speicherung besteht. Die Löschung wird auf Anfrage bestätigt.

§ 8 Pflichten des Auftraggebers

Der Auftraggeber ist für die Rechtmäßigkeit der Verarbeitung verantwortlich, insbesondere für die Information seiner Endkunden (Art. 13 DSGVO), etwa in seiner Datenschutzerklärung und mit der bereitgestellten Kundeninfo. Er gibt in Zahlungslinks und Projektbeschreibungen nur die für die Zahlung erforderlichen Daten an, insbesondere keine Gesundheitsdaten oder sonstigen besonderen Kategorien personenbezogener Daten. Er informiert den Auftragnehmer unverzüglich, wenn er Fehler oder Unregelmäßigkeiten feststellt.

§ 9 Haftung und Schlussbestimmungen

Für die Haftung gilt Art. 82 DSGVO; im Übrigen gelten die Haftungsregeln des Dienstleistungsvertrags. Bei Widersprüchen geht dieser Vertrag dem Dienstleistungsvertrag in Fragen des Datenschutzes vor. Änderungen bedürfen der Textform. Es gilt deutsches Recht.

Ort, Datum · Auftraggeber (Studio)

Name: _____

Ort, Datum · Auftragnehmer

DSX Media Solutions UG (haftungsbeschränkt)

Anlage 1 · Art, Zweck und Umfang der Verarbeitung

Zweck	Bereitstellung der Tattoofin-Zahlungsstruktur für das Studio des Auftraggebers: Erstellung und Bereitstellung von Zahlungslinks und der Zahlseite, Anzeige des Zahlungsstatus und der Zahlungsübersicht im Studio-Portal, Versand von Benachrichtigungen an den Auftraggeber und gegebenenfalls an Endkunden, Support, Abrechnung der Vergütung.
Art der Verarbeitung	Erfassung, Speicherung, Übermittlung an Stripe über die Stripe-Connect-Schnittstelle, Abruf des Zahlungsstatus, Anzeige, Versand per E-Mail, Löschung.
Betroffene Personen	Endkunden und Interessenten des Auftraggebers; Mitarbeitende des Auftraggebers mit Zugang zum Studio-Portal.
Datenarten	Endkunden: Name, E-Mail-Adresse, gegebenenfalls Telefonnummer (soweit für den Versand eingegeben), Betrag, Projektbeschreibung (z. B. „Sleeve linker Arm, Anzahlung“), Zahlungsstatus, Zahlungszeitpunkt, gewählte Zahlungsart, technische Referenzen der Zahlung bei Stripe. Mitarbeitende: Name, E-Mail-Adresse, Zugangsdaten, Protokolldaten der Anmeldung. Karten- und Bankdaten sowie Daten zur Bonitätsprüfung verarbeitet ausschließlich der jeweilige Zahlungsanbieter; der Auftragnehmer erhält sie nicht.
Besondere Kategorien	Werden nicht erhoben. Der Auftraggeber trägt in Projektbeschreibungen keine Gesundheitsdaten oder sonstigen besonderen Kategorien ein (§ 8).

Anlage 2 · Technische und organisatorische Maßnahmen (Art. 32 DSGVO)

Zugangs- & Zugriffskontrolle	Zugriff auf Systeme und Konten der eingesetzten Dienste nur für benannte Personen; personalisierte Zugänge; starke Passwörter und Zwei-Faktor-Authentifizierung, wo verfügbar; Rechte nach dem Need-to-know-Prinzip; Entzug der Zugänge bei Ausscheiden. Zugang zum Studio-Portal nur mit persönlichen Zugangsdaten des Studios.
Weitergabekontrolle	Übertragung ausschließlich verschlüsselt (TLS); Kommunikation mit Stripe nur über die offizielle Schnittstelle mit geheimen Schlüsseln, die nicht im Browser gespeichert werden; Benachrichtigungen nur an die vom Auftraggeber hinterlegten Empfänger.
Eingabe- & Auftragskontrolle	Protokollierung der Erstellung von Zahlungslinks und relevanter Systemereignisse; dokumentierte Konfiguration je Studio; schriftliche Verträge mit Unterauftragsverarbeitern.
Datenminimierung	Zahlungslinks enthalten nur die für die Zahlung erforderlichen Angaben; keine Speicherung von Karten- oder Bankdaten beim Auftragnehmer; Löschung nach § 7.
Verfügbarkeit & Belastbarkeit	Einsatz etablierter Cloud-Dienste mit eigener Redundanz; Zahlungsdaten zusätzlich im Stripe-Konto des Auftraggebers verfügbar; Überwachung der Funktion.

Trennungsgebot	Logische Trennung der Daten je Auftraggeber; Zuordnung über eindeutige Studio-Kennungen und das jeweilige Stripe-Konto.
Überprüfung	Regelmäßige Überprüfung der Maßnahmen und der Unterauftragsverarbeiter, mindestens jährlich.

Anlage 3 • Genehmigte Unterauftragsverarbeiter

Dienst	Anbieter	Zweck	Ort / Garantie
Hosting & Datenspeicher	Netlify, Inc., San Francisco, USA	Betrieb von Website, Studio-Portal, Zahlseite und Datenspeicher	[laut DPA prüfen: Region, SCC/DPF]
E-Mail-Versand	[Anbieter laut Einsatz eintragen, z. B. Resend, Inc. oder SMTP-Dienst]	Versand automatischer Benachrichtigungen	[laut DPA prüfen]
E-Mail & Büro	Google Ireland Ltd. (Google Workspace)	E-Mail-Kommunikation, Support, Ablage von Abrechnungsunterlagen	EU / SCC/DPF [laut DPA prüfen]
Plattformkonto Stripe Connect	Stripe Payments Europe, Ltd., Dublin, Irland	Nur soweit Daten im Plattformkonto des Auftragnehmers verarbeitet werden (z. B. Metadaten zu Zahlungslinks, Plattformgebühren). Die Zahlungsabwicklung selbst erfolgt im Vertragsverhältnis zwischen Auftraggeber und Stripe (§ 1 Abs. 2).	EU / [laut DPA prüfen]

Stand 10/2026. Änderungen werden nach § 4 Abs. 2 mitgeteilt.